

PeerLink KACST Quarterly VA Evidence Index — 2026 Q3

Assessment: PeerLink-2026-Q3-VA

Date: 11 August 2026

Purpose: map every conclusion to reproducible or reviewable evidence without committing credentials, cookies, full OCI identifiers, or oversized raw scanner exports.

Committed, sanitized evidence

Evidence	Path / identifier	Supports
Formal assessment report	docs/Reports/PeerLink-KACST-Quarterly-Vulnerability-Assessment-2026-Q3.md	Scope, method, results, conclusion
Findings and remediation register	docs/Reports/PeerLink-KACST-Quarterly-VA-Findings-Register-2026-Q3.md	Severity, confidence, status, retest, open actions
Public web/network baseline	docs/Reports/evidence/2026-Q3/production-web-baseline.txt	Redirect, TLS, cert, headers, CORS, methods, OpenAPI, ports
Sanitized tool summary	docs/Reports/evidence/2026-Q3/tool-results-summary.json	Audit/scan counts and regression summary
Initial real browser evidence	BrowserOps task 20260811-144834-peerlink-quarterly-va-production	Rendered production site over HTTPS
Final post-production browser evidence	BrowserOps task 20260812-004645-peerlink-post-production-full-verification	Live rendered application after final browser-header remediation
Final application/security workflow	GitHub Actions run 31539611417, commit bdb03b5	Frontend rebuild, service verification, 32 tests and live lockout acceptance
Quarterly process/architecture	docs/architecture/quarterly-vulnerability-management.md	Repeatable control, triage and evidence lifecycle
Quarterly schedule	docs/security/quarterly-vulnerability-assessment-schedule.md	Future windows and responsibilities
Repeatable runner	scripts/run_quarterly_vulnerability_assessment.sh	Safe evidence collection procedure
Implementation log	docs/Logs/2026-08-11-005-kacst-quarterly-vulnerability-assessment.md	Chronology, changes and validation

Raw internal evidence retained outside Git

The following working files were produced on the personal Mini PC during the assessment. They are intentionally not committed because raw exports may contain infrastructure identifiers, excessive scanner detail, or machine-specific paths.

Evidence class	Local working artifact	Sanitization
OCI host scan summary/detail	/tmp/peerlink-vss-agent.json , /tmp/peerlink-vss-agent-detail.json	Counts and mapped-package result copied to tool summary/report; OCIDs omitted

Evidence class	Local working artifact	Sanitization
OCI CIS result/detail	/tmp/peerlink-vss-cis-benchmark.json , /tmp/peerlink-vss-cis-detail.json	17/18 and failed control copied; OCIDs omitted
OCI port result/detail	/tmp/peerlink-vss-port.json , /tmp/peerlink-vss-port-detail.json	Publicly relevant ports summarized; VNIC/instance IDs omitted
Python dependency audit	/tmp/peerlink-pip-audit-final.json	Package/advisory residual summarized
Bandit	/tmp/peerlink-bandit-final.json	Severity totals and manual disposition summarized
Trivy images	/tmp/peerlink-trivy-backend-final.json , /tmp/peerlink-trivy-frontend-final.json	Severity/fixability counts summarized
Gitleaks	/tmp/peerlink-gitleaks-tracked.log	Zero-result and bytes scanned summarized
Public checks	/tmp/peerlink-production-web-evidence.txt , /tmp/peerlink-public-port-evidence.txt	Sanitized into committed baseline
Build/test logs	/tmp/peerlink-*build*.log , /tmp/peerlink-unittest.log , /tmp/peerlink-validation.log	Pass/fail totals summarized
Direct deployed-image scans	OCI VM .security-assessment/production-direct-20260811T214422Z/	Actual backend/frontend image Trivy JSON, repository scan and SHA-256 checksums
Direct VM verification	Mini PC operational SSH audit on 12 August 2026 AST	Runtime commit/configuration, services, migration, backups, tests, ports, headers, package status and effective SSH controls
GitHub alert reconciliation	/tmp/peerlink-dependabot-open-current.json on Mini PC	27 default-branch npm alerts contrasted with zero current production-branch npm audit findings

Raw /tmp artifacts are working evidence, not durable records. Before any external submission, export approved raw evidence to the controlled internal evidence store if policy requires retention, redact identifiers, and calculate checksums.

Reproduction commands

Repeatable runner

```
scripts/run_quarterly_vulnerability_assessment.sh \
--production-url https://p2p.iiootsolutions.sa \
--backend-image peerlink-va-backend:2026q3-final \
--frontend-image peerlink-va-frontend:2026q3-final
```

The output defaults to untracked .security-assessment/<UTC timestamp>/ and includes per-step logs and SHA-256 checksums.

Local acceptance

```
P2P_ACCEPTANCE_PROJECT=p2p-va-acceptance \
python3 scripts/run_failed_login_acceptance.py

P2P_ACCEPTANCE_PROJECT=p2p-va-acceptance \
python3 scripts/run_session_control_acceptance.py
```

Compose validation

```
P2P_POSTGRES_PASSWORD=x \  
P2P_POSTGRES_PASSWORD_URLENCODED=x \  
P2P_MONGO_PASSWORD=x \  
P2P_MONGO_PASSWORD_URLENCODED=x \  
P2P_SECRET_KEY=01234567890123456789012345678901 \  
docker compose -f docker/docker-compose.yml config -q
```

Evidence integrity and claim rules

1. Never include `.env`, credentials, OTPs, cookies, session handles, API keys or unredacted secret-scan matches.
 2. Keep scanner output separate from confirmed applicability; report confidence and mapping.
 3. Label every result as production-observed, local candidate, or pending production retest.
 4. Do not use accelerated acceptance timing as a claim of real-duration production observation.
 5. Do not edit old evidence to imply a later deployment. Append a dated production-retest record.
 6. Send the package to Aadil for review first; do not submit directly to KACST or Dr. Ibrahim without approval.
-

Generated from the approved internal report source for Aadil Feroze's review. Do not forward to KACST without internal approval.